

Secure Document Handling & Storage Plan

This document outlines a secure and scalable approach for handling documents in enterprise and banking applications. The current implementation uses Base64 encoding, which is not considered secure because it only encodes data and does not provide encryption or protection against unauthorized access.

1. Recommended Secure Architecture

- Upload original document securely through authenticated APIs.
- Encrypt files using AES-256 encryption before storage.
- Store encrypted documents in secure storage (Server, S3, MinIO, or Blob Storage).
- Maintain metadata such as file name, checksum, upload date, and owner.
- Use Role-Based Access Control (RBAC) for file access.
- Allow downloads only through authenticated and authorized APIs.
- Enable HTTPS/TLS for all communication.
- Maintain audit logs for uploads, downloads, and modifications.

2. Security Comparison

Method	Security Level	Recommended
Base64 Encoding	Low (Encoding only)	No
AES-256 Encryption	High	Yes
SHA-256 Hashing	Verification only	Partial
JWT/Token Access	Medium-High	Yes
RSA/PGP Encryption	Very High	For highly sensitive files

3. Best Practices for Banking & Trade Finance Applications

- Use AES/GCM/NoPadding for modern secure encryption.
- Store encryption keys securely using KMS or HSM.
- Validate file types and MIME types before upload.
- Enable antivirus/malware scanning for uploaded files.
- Disable direct URL access to documents.
- Generate temporary signed URLs for downloads.
- Maintain document checksum using SHA-256.
- Enable logging and monitoring for document operations.

4. Suggested Technology Stack

- Backend: Java + Spring Boot
- Authentication: Spring Security + JWT
- Encryption: AES-256
- Storage: MinIO / AWS S3 / Secure File Server
- Database: MySQL / Oracle
- Transport Security: HTTPS/TLS
- Audit Logging: ELK / Splunk / DB Audit Tables

Replacing Base64-only storage with AES-256 encrypted document handling significantly improves application security, compliance, and scalability. This approach is suitable for enterprise-grade banking and Trade Finance systems.